ACC-13 · Account Suspension for Misuse or Policy Investigation

IT contains. The department head, HR or senior leadership sanctions. What the organization suspends, on what basis, what it hands over, and what the person is told.

Field	Value
Document ID	ACC-13
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	B. Account Usage
Operating tier	Tier 4 — IT Management authorises every suspension beyond immediate containment, and owns every referral. Tier 3 executes and assembles the evidence. Tier 1 and Tier 2 contain and escalate; they do not suspend and they do not refer.
Review cycle	Annually, jointly with HR.
Relationship to ACC-03 and ACC-15	One ladder, three views. ACC-03 §9 governs the technical response to repeat compromise; ACC-15 §5 governs the acceptable-use side; this document governs suspension and referral. Where the three disagree, ACC-03 governs the technical action and this document governs the referral, and the divergence is reported as a defect under GOV-01 §10.

1. The distinction this document exists to protect

A familiar case: an account is blocked for the third time in a month. The person is told not to use a VPN or to share access with anyone. Across that month, several similar IP addresses have passed multifactor authentication on the account, consistent with the credential being shared. Everything IT does is reasonable, and the instinct to involve the person’s manager is right.

What IT usually does not have is a written ladder, a defined referral, or a rule about what it could properly assert. In a matter that touches a person’s standing at the organization, those absences matter more than they do anywhere else in this catalogue — because the consequence of getting it wrong is not an outage, it is an unfair outcome that nobody intended and nobody can undo.

> **Two different actions. IT takes only one of them.**
>
> A SECURITY ACTION is containment. Sign-in is blocked because the account is behaving as though it is compromised or shared. It is not a punishment. It requires no finding of fact about the person. It can be taken quickly, by a technician, on a reasonable technical basis — and it should be, because speed is the whole value of it. It is reversed as soon as the technical position is resolved.
>
> A DISCIPLINARY ACTION is a sanction against a person for something they are said to have done. It requires a finding, a process, and somebody with the authority to make it. It is never IT's to take, and it is never IT's to imply.
>
> IT CONTAINS. The person's manager or department head, Human Resources or senior leadership SANCTIONS. Where an IT action starts to function as a punishment — held longer than the technical need, applied to make a point, or described to the person in the language of consequence — the boundary has been crossed, and it is raised with Tier 4 the same day rather than argued about later.

This is not a technicality. Blocking someone's account is, in its effect on them, a serious thing: they cannot do their work, read their mail, reach the systems they depend on, or contact the people they work with. Doing that for a security reason is proper and defensible. Doing it as a sanction, without a process, because a technician formed a view of the case, is neither — and it would not survive being examined by anybody outside IT.

Holding the boundary is also what protects IT. A department that contains and refers is doing its job. A department that adjudicates has taken on a responsibility it has no authority for, no training in, and no way of discharging fairly.

2. Who decides what

Action	Decided by	Executed by	Basis required
Block sign-in, revoke sessions, force a password reset	Tier 2 or Tier 3, on the technical facts	Tier 2 / Tier 3	A reasonable technical basis, recorded in one sentence. No finding about the person.
Re-register all multifactor methods	Tier 2 or Tier 3	Tier 2 / Tier 3	As above (ACC-03 §9).
Hold the block beyond the technical need, pending review	Tier 4	Tier 3	A Tier 4 decision, recorded, with a review date. This is the point at which containment stops being routine.
Refer the matter to the department head or HR	Tier 4	Tier 3 assembles, Tier 4 sends	A referral packet meeting §6.
Suspend the account for the duration of a disciplinary process	The person's department head, HR or senior leadership — not IT	Tier 3	A written instruction from that office.
Impose any sanction on the person	The person's department head, HR or senior leadership	Not IT	Their process. IT has no part in it.

Action	Decided by	Executed by	Basis required
Restore access	§10 — depends on the route in	Tier 2 / Tier 3	Technical resolution, or written release from the office holding the matter.
Read the person’s mail, files or Teams content	Only under M365-16 §8	Tier 3, with Tier 4 authorisation	Written authorisation from an authority named in M365-16 §8. Never on a request to the service desk.

3. The ladder

The ladder exists so that the response does not depend on who picks up the ticket. Its first rungs are ordinary and should feel ordinary — most breaches are somebody helping a friend, or not realising.

Rung	Trigger	IT action	Referral
1	First block, cause identified, no sign of harm.	Restore per ACC-05. Record the confirmed cause. Explain the rule and point at the Acceptable Use Policy (ACC-15 §3).	None. No further consequence.
2	Second block within 90 days.	Restore. Review sign-in history for shared-credential and unfamiliar-location patterns. Re-register every multifactor method. Brief the person again, in writing this time. Flag for watch.	None yet. Tier 3 informed.
3	Third block within 90 days — the §1 case.	Treat as suspected sharing or compromise until shown otherwise. Force reset, revoke sessions and tokens, remove and re-register every method. Preserve the sign-in evidence before remediating (GOV-03 §6).	Tier 4 decides whether to refer. The department head or manager is notified in writing either way.
4	Sharing or misuse indicated by evidence that survives §5.	Containment held on a recorded Tier 4 decision with a review date. Referral packet assembled (§6).	The person’s department head, or HR for employees. The person is told (§8).
5	Credentials sold, or used to obtain something of value; or serious misuse of organization systems.	Suspend. Preserve evidence before remediating. Declare an incident under GOV-03.	Tier 4 declares. The department head or HR, and potentially beyond the organization.
6	A wider policy investigation is under way.	IT supplies the technical facts under §11 and nothing else. IT takes no view.	The organization’s investigation process, through HR or the relevant department head.

> **Two cautions to carry up the ladder**
>
> A REPEAT COUNT IS NOT EVIDENCE. A person with one multifactor method and an unreliable phone will legitimately appear three times in ninety days. So will an account with a stale credential on an old device retrying in a drawer. Establish the cause each time (ACC-05 §2) — the count tells you to look, not what you will find.
>
> The rungs are not a countdown to a sanction. Most accounts that reach rung 3 have a technical explanation, and finding it is a better outcome for everybody than a referral. Rung 4 requires evidence that has survived §5, not a third occurrence.

---

4. Containment — proportionate, fast, and time-limited

4.1 Proportion

Contain the smallest thing that works. Where the concern is one application, block the application. Where it is one session, revoke the session. A full account block is the largest available action, and it should be recognisable as such by the person taking it rather than reached for as the default.

4.2 The sequence

1. PRESERVE FIRST. Capture the sign-in records, the multifactor registration history and the relevant audit data before remediating. Once sessions are revoked and credentials changed, the trail is materially harder to reconstruct, and it is the trail that later decides whether this was sharing, compromise or nothing (GOV-03 §6).
2. Block sign-in and revoke sessions and tokens.
3. Force a password reset and remove all multifactor methods for re-registration (ACC-03 §9).
4. Record the technical basis in one sentence, in neutral terms — what was observed, not what it is thought to mean (§5).
5. Notify the person promptly, through a channel independent of the suspended account (§8). This is a step in the procedure, not a courtesy to be fitted in later.
6. Escalate to Tier 4 if the block will be held beyond the technical need, or if any referral is contemplated.
7. Where several accounts share the same indicators — open ONE investigation, not several tickets, and notify Tier 3 (ACC-03 §10). Splitting a single pattern across six tickets is how it stops looking like a pattern.

> **Containment has a clock, and somebody has to be watching it.**
> A containment block still in place after FIVE COVERAGE DAYS without either restoration or a Tier 4 decision to hold it is escalated to Tier 4 automatically, by whoever notices, without waiting to be asked.
> Containment that has quietly become indefinite is a sanction that nobody decided to impose. It has all the effect of a suspension and none of the process, and it usually happens not through any intent but because the ticket moved down the queue.
> In a small, stretched team, tickets do move down queues. That is precisely why this one carries an automatic escalation rather than relying on somebody remembering.

5. Evidence, and the discipline of not over-claiming

The technical signals available are genuine and useful, and every one of them means less on its own than it appears to. This table is written so that a referral describes what is actually known.

Signal	What it indicates	What it does not establish
Several accounts authenticating from the same or similar IP addresses — the §1 observation	Shared network egress. Consistent with one person operating several accounts, or with a credential being shared.	It does not establish sharing. A shared office building, a site network, a mobile carrier's address translation, a public VPN exit node, a coffee shop or a family home all put many unrelated people behind one address. This is an INDICATOR, not proof, and the difference is the whole of this section.
Multifactor approvals from a device other than the registered one	The second factor is being approved somewhere unexpected.	It does not establish who approved it. People replace phones, register a second method and forget, or approve from a tablet.
Concurrent sessions from geographically impossible locations	A strong technical indicator that the credential is in more than one pair of hands.	It does not distinguish SHARING from COMPROMISE — which are entirely different matters with entirely different outcomes for the person, one of whom is a victim.
VPN or proxy egress	The sign-in location is obscured.	Not misconduct in itself. People use VPNs legitimately, for reasons that are nobody's business (DEV-10). It becomes relevant only alongside something else.
Repeat lockouts	A recurring problem with the account.	More often a stale credential on a forgotten device than a person doing anything at all (ACC-05 §2).
Sign-in from an unexpected country	Worth investigating, promptly.	People travel, families are international, and a work trip abroad looks exactly like a compromise on its first day.

> **IT presents evidence. IT does not present conclusions.**
>
> The temptation runs entirely the other way, and it is worth naming because it is strong. It is quicker, clearer and more satisfying to write “the person has been sharing their account” than to write “over 24 days, sign-ins on this account were granted from eleven distinct IP addresses across four subnets, of which the account holder’s registered device accounts for two.”
>
> The second sentence is what IT knows. The first is a FINDING, and it belongs to the person conducting the process — who will weigh it against things IT cannot see: a housemate, a reasonable adjustment, a family emergency, a device lent for an afternoon, or a compromise the account holder is the victim of.
>
> Where IT writes the conclusion into the referral, the department head is no longer deciding — they are ratifying a decision IT has already made and has no authority to have made. That is a poor position for both offices, and it is exactly the position that fails when a case is challenged.
>
> The practical test before sending: could every sentence in this packet be read aloud to the account holder without IT having to defend an inference? If not, rewrite it as an observation.

---

6. The referral packet

Assembled by Tier 3, approved and sent by Tier 4, addressed to the office that holds the process. Appendix A is the template. One packet per person.

6.1 What it contains

- The account holder, their affiliation, and the account concerned.
- A factual chronology with dates and times: what was observed, when, and what IT did in response at each point.
- The technical evidence, described in the terms of §5 — observations, with their limits stated. A signal presented without its limit is a signal presented misleadingly.
- The rule said to be engaged, quoted from the acceptable use policy rather than paraphrased (ACC-15).
- What the person has already been told, and when, and by whom.
- The current state of the account, and what IT will do next absent instruction.
- A named IT contact who can answer technical questions about the packet.

6.2 What it must not contain

- A conclusion, a characterisation of the person, or a recommendation as to sanction (§5).
- Unrelated ticket history. That somebody has been difficult with the service desk is not evidence of anything and does not belong in a disciplinary file.
- The content of the person’s mail, files or Teams messages — unless obtained under written authorisation through M365-16 §8, in which case the authorisation is attached and named (§9).
- Another person’s data. Where the same indicators implicate other account holders, they are referred separately or redacted. A packet about one person that names three is a second disclosure problem inside the first.
- Speculation about motive. IT does not know why, and saying so is more useful than guessing.

7. Notification — who is told, when, and by whom

Who	When	What they are told	By whom
The account holder	Within 1 coverage day of the block	That access has been suspended, the general reason, who took the decision, what happens next, and who to contact (§8).	Tier 3, or the referring office where a process has begun
The person's department head	At rung 3, informed; at rung 4, referred	The packet, or a notification that a third block has occurred.	Tier 4
Human Resources (employees)	At rung 3 onwards	The same, and HR is involved from the start rather than afterwards (ACC-15 §6).	Tier 4
The person's manager	Where operationally necessary	That access is suspended and roughly for how long. Not the evidence, and not a characterisation.	Tier 4
Tier 4 and IT Security	At rung 3 onwards, immediately at rung 5	Everything.	Tier 3
Counsel	Where a matter may become formal or external	On the Head of IT's judgement, early rather than late.	Head of IT
Colleagues, the wider department	Never	Nothing. A suspension is not announced, and an out-of-office implying misconduct is never set.	—

8. What the person is told, and the right of appeal

A person whose account has been suspended is entitled to know five things, and none of them requires IT to disclose investigative detail or prejudices any process:

- THAT it has happened — promptly, in plain language, and not by discovering it at a sign-in prompt.
- The GENERAL REASON, in terms they can understand. "Your account has been suspended because of activity consistent with the credential being used by more than one person" is honest, and it discloses nothing that helps anybody evade anything.
- WHO took the decision, and on what authority.
- WHAT HAPPENS NEXT, and roughly when. "We do not have a date yet, and I will tell you when we do" is a legitimate answer; silence is not.
- WHO THEY MAY SPEAK TO, and to whom any appeal is made — which is the office holding the process, not IT.

> **Send the notice somewhere they can actually read it.**
>
> The obvious failure: the notice is sent to the organization mailbox of the account that has just been suspended. Nobody intends this; it happens because the address is the one on the record.
>
> The notice goes to the alternate contact on file, or is delivered through the person's manager or HR. Where no alternate contact exists, that is itself a finding to fix, and the notification is made by telephone with a note on the ticket recording the call.
>
> A person who cannot sign in and cannot find out why will conclude something has broken, open tickets, ask friends, and eventually arrive at the service desk distressed — which serves nobody, and puts a Tier 1 technician in the position of explaining something they were never told.

IT cannot restore an account held under a disciplinary process, and should say so plainly rather than implying a discretion it does not have. The correct sentence is: "I am not able to restore this; the office handling it is X, and here is how to reach them." Anything vaguer sends the person back and forth between two offices, each believing the other is deciding.

---

9. What IT will not do

Stated positively, so that a technician under pressure from somebody senior has something to point at.

- IT WILL NOT READ A PERSON'S MAIL OR FILES TO BUILD A CASE. Access to a mailbox, OneDrive or Teams content for investigative purposes happens only under written authorisation through the routes in M365-16 §8. A request from a department head, a manager, a family member, a colleague or an executive — however senior, however urgent, however reasonable it sounds — is declined and referred to that section. This is the single most important sentence in this document.
- IT will not suspend an account at the request of a third party without a recorded Tier 4 decision. "The department head wants this account blocked" is a request, not an instruction, until it is in writing from the department head.
- IT will not characterise a person's conduct in a ticket, an email or a referral (§5). Tickets are read by many people and retained for years.
- IT will not discuss a suspension with anybody outside the §7 list — including a family member, however close. The organization has an office for that conversation and it is not the service desk.
- IT will not restore access to end an argument, to relieve pressure, or as a favour. If restoration is right, it is right under §10 and recorded.
- IT will not hold a suspension in place because a referral has gone quiet. It escalates to Tier 4 and asks (§4.2).
- IT will not use access — or the restoration of it — as leverage to obtain an explanation from the person. That is an interrogation conducted by a technical department, and it is not the organization's to conduct.

10. Restoration

Route in	Who releases it	Conditions
Containment only; the technical position is resolved	Tier 2 or Tier 3	Password reset, all multifactor methods re-registered, sessions revoked and confirmed, cause recorded.
Referral concluded with no action	The referring office, in writing	As above, plus a recorded note that the matter concluded without action (§10.1).
Referral concluded with a sanction that permits access	The office holding the process	As above, plus any conditions that office attaches. IT applies conditions; it does not set them.
Sanction that does not permit access	Not restored	The account follows the sanction. Where the sanction is separation or dismissal, ACC-01 §7 and ACC-12 apply from that point.
Compromise by a third party — the person was the victim	Tier 3	Full recovery per ACC-03 §9, an apology for the disruption, and no referral. This case exists and is regularly mistaken for the first.

10.1 Restoration is recorded as carefully as suspension

A person who was suspended and then cleared must have a record that says so. Without one, the suspension is the only thing on file, and it will be read years later by somebody who has no way of knowing how it ended. This is a small administrative act with a large effect on fairness, and it is the step most often skipped because by then everybody has moved on.

- The ticket records the outcome in a sentence, and the outcome is written even when it is “no action taken”.
- A watch flag may be set for 90 days after a rung 3 or 4 restoration. It is a technical monitoring measure, it is time-bound, and it is removed on schedule rather than left in place.
- The conversation about the rule happens at restoration, not at suspension, and it is a conversation rather than a warning (ACC-15 §3).

11. Policy investigations — the narrow role IT plays

IT has no role in deciding a policy or disciplinary investigation, and should be careful not to acquire one through helpfulness. The risk here is not obstruction; it is a technician answering a reasonable question from a staff member and, in doing so, becoming the source of evidence in a process with no record of how the evidence was obtained.

IT can properly supply, on authorised request	IT does not supply
Sign-in records: times, locations, addresses, device and application, with the §5 limits stated.	An opinion on what the records mean.
Multifactor registration and approval history.	An inference about who was holding the device.

IT can properly supply, on authorised request	IT does not supply
Device compliance and enrolment state, where the device is organization-managed (DEV-02).	Anything about a personally-owned device beyond what the organization legitimately holds (DEV-07).
Confirmation that an account was blocked, when, and for what technical reason.	A characterisation of the person's conduct or history.
Timestamps from a system IT operates, where they exist as ordinary records.	Mail, file or Teams content — that is M365-16 §8, and it is a different authorisation entirely.

- The request comes from the department head or senior leadership with a case reference, and it is answered in writing. A staff member asking the service desk directly is redirected — not because the question is improper, but because the answer becomes evidence, and evidence needs a route that can be described afterwards.
- IT answers the question asked. It does not volunteer adjacent findings, and it does not run additional searches because they might be useful.
- Where the technical position is genuinely ambiguous, IT says so in the answer. An honest "these records are consistent with both explanations" is far more valuable to the process than a confident answer that turns out to be wrong.

12. Service levels

Activity	Commitment (per GOV-06)
Containment on a reasonable technical basis	P1 — immediate. Containment is never queued, and never waits for an approval.
Notice to the account holder	Within 1 coverage day of the block, through a channel they can reach (§8).
Tier 4 decision on holding a block beyond the technical need	Within 2 coverage days. Absent a decision, the block is released or escalated — not left running.
Automatic escalation of an unresolved containment	At 5 coverage days, by whoever notices (§4.2).
Referral packet assembled and sent	Within 3 coverage days of the Tier 4 decision to refer.
Restoration once released in writing	Same coverage day.
Authorised evidence request from an HR or investigation process	Within 5 coverage days, in writing (§11).
Rung 5 — sale of credentials, or serious misuse	P1, incident declared under GOV-03.

13. Records

Retention here is longer than elsewhere in the catalogue, because these records are the organization's evidence that it acted properly — and that question is asked long after the event, by people who were not there.

Record	Held in	Retention
Containment actions, with the one-sentence technical basis	Ticket	3 years
Preserved technical evidence (sign-in, MFA, audit extracts)	Security record	7 years
Tier 4 decisions to hold, refer, or release	Tier 4 record	7 years
Referral packets, as sent	Security record; the process file sits with the referring office	7 years
Notice issued to the account holder	Ticket + security record	7 years
Outcome of the referral, including “no action taken”	Security record	7 years — §10.1
Restoration, with conditions applied	Ticket	3 years
Authorised evidence supplied to an HR or investigation process	Security record	7 years
Authorisations obtained under M365-16 §8	IT governance record	7 years

14. Related documents

ID	Title	Relationship
ACC-15	Acceptable Use & Credential-Sharing Standard	The rule that is engaged, and the same ladder from the acceptable-use side (ACC-15 §5).
ACC-03	MFA Enrollment & Account Recovery	§9 repeat-incident escalation and §10 risky sign-in. Governs the technical response.
ACC-05	Account Lockout Triage & Escalation	§2 — establish the cause before drawing any inference from a repeat count.
M365-16	Retention, Legal Hold & eDiscovery Request Handling	§8 — the ONLY route by which a person’s mail or files may be searched. §9 of this document depends on it entirely.
GOV-03	Security Incident Response	Preserve before you fix; rung 5 declaration.
GOV-01	SOP Catalog Governance	§10 — reporting a divergence between this ladder and ACC-03 or ACC-15.
DEV-10	Remote Access & VPN Standard	§5 — VPN use is not misconduct in itself.
DEV-14	Endpoint Security Agent & MDR Escalation Standard	Where a detection from the managed partner starts the chain.
DEV-02	Device Compliance & Configuration Baseline	§11 — device state as an ordinary record.

ID	Title	Relationship
DEV-07	Personally-Owned Device Access Standard	§11 — the limit of what the organization holds about a personal device.
ACC-01	Account Lifecycle	Where a sanction ends the relationship.
ACC-12	Separation, Retiree & Former-Member Disposition	The disposition that follows a separation or dismissal.
ACC-06	Identity Verification Before Any Account Action	Verification before restoring anything.
AUP	Your organization's acceptable use policy	The governing policy. Quoted in a referral, never paraphrased.

Appendix A — The referral packet template

Assembled by Tier 3, approved and sent by Tier 4. Every entry is an observation. If a field cannot be completed factually, it is left blank and the gap is stated — a blank is honest, a guess is not.

Field	Entry
Referred to	HR / the department head / senior leadership
Date, and referring authority	Tier 4 approver, named
Account holder	Name, affiliation, ID, account
Current account state	Blocked since [date]. Sessions revoked. Credentials reset.
Rule said to be engaged	Quoted from the acceptable use policy, with the section reference
Chronology	Dated entries. What was observed, and what IT did at each point. No commentary.
Technical observations	Each stated with its limit, per §5. For example: “Over 24 days, sign-ins were granted from eleven distinct IP addresses across four subnets. Two correspond to the account holder’s registered device. Shared network egress can place unrelated people behind a single address; this is an indicator, not proof.”
What IT does NOT know	Stated explicitly. This field is not optional and it is not a formality.
What the person has been told, and when	Copy of the notice issued under Appendix B
Other account holders implicated?	YES requires a separate referral or redaction — never named here (§6.2)
Was any mail, file or Teams content examined?	NO / YES — if YES, the M365-16 §8 authorisation is attached and named. Absent that authorisation the answer is NO.

Field	Entry
What IT will do next absent instruction	For example: “The block remains in place pending your response. Absent a decision by [date] it will be escalated to the Head of IT under §4.2.”
Named IT contact for technical questions	Name, role, address
— NOT INCLUDED —	No conclusion. No recommendation as to sanction. No characterisation of the person. No unrelated ticket history.

Appendix B — Notice to the account holder

Sent within one coverage day of the block, to an address the person can actually reach — not the suspended mailbox. Plain, calm, and short. This text is a starting point, not a form to send unedited.

Subject	Your organization account
Opening	We have suspended sign-in on your organization account. I am writing to tell you that directly, so that you are not left to find out at a login screen.
What has happened	On [date] we blocked sign-in on your account. The reason is [general, factual reason — for example: activity on the account consistent with the credential being used by more than one person]. This was done as a security measure to protect the account. It is not a decision about you, and it is not a penalty.
Who took the decision	The decision was taken by [role] in IT, under the organization’s Account Suspension standard.
What happens next	[Either: We expect to restore access once [technical condition] is complete, which we expect by [date]. Or: The matter has been referred to [office], who will be in touch with you. IT is not able to restore access while that is in progress.]
What you can do now	If you believe your account was used by someone else without your knowledge, please tell us — that changes what we are looking at, and it is much better for us to know early. If you need access to something urgent in the meantime, tell us what it is and we will see what we can arrange.
Who to contact	For technical questions: [named IT contact]. For questions about the referral or the process itself, or to appeal: [named office and contact]. IT cannot answer those and will not try to.
Closing	We know this is disruptive, and we are not leaving it sitting. Please do get in touch.
Tone note (not sent)	Nothing in the notice implies a finding. Nothing in it uses the language of discipline. If a sentence would read badly when quoted back at a hearing, it is the wrong sentence.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.